

程式碼實驗室：Trusted Space

來源：<https://codelabs.developers.google.com/codelabs/trusted-space?hl=zh-tw>

步驟數：5

在本程式碼研究室中，您將瞭解如何使用 Trusted Space 解決方案，透過加速器執行 AI/ML 工作負載。

目錄

1. [1. 總覽](#)
2. [2. 設定雲端資源](#)
3. [3. 建立工作負載](#)
4. [4. 授權及執行工作負載](#)
5. [5. 清除](#)

1. 總覽

準備好提升 GPU 加速工作負載的安全性和隱私權了嗎？本程式碼實驗室將引導您瞭解 **Trusted Space** 的功能。這項服務提供強大的操作人員隔離機制和加速器支援功能，非常適合用於機密的 AI/機器學習工作負載。

保護重要資料、模型和金鑰比以往更加重要。Trusted Space 可確保工作負載在安全可靠的環境中運作，即使是工作負載運算子也無法存取，因此是理想的解決方案。

「安全空間」提供以下功能：

- **強化隱私權和安全性：**Trusted Space 提供受信任的執行環境，可透過加密證明保護您的機密資產 (例如模型、重要資料和金鑰)。
- **運算子隔離：**消除運算子干擾的疑慮。有了 Trusted Space，即使是工作負載運算子也無法存取，防止他們透過 SSH 連線、存取資料、安裝軟體或竄改程式碼。
- **加速器支援：**Trusted Space 可與各種硬體加速器順暢搭配運作，包括 H100、A100、T4 和 L4 等 GPU。確保對效能要求嚴苛的 AI/機器學習應用程式順利運作。

課程內容

- 瞭解 Trusted Space 的主要服務。
- 瞭解如何部署及設定 Trusted Space 環境，保護 AI/機器學習工作負載的重要資產。

軟硬體需求

- Google Cloud Platform 專案
- 具備 [Google Compute Engine](#) 和 [加速器](#) 的基本知識。
- 對 [服務帳戶](#)、[金鑰管理](#)、[Workload Identity Federation](#) 和 [屬性條件](#) 有基本瞭解。
- 對 [容器](#) 和 [Artifact Registry](#) 有基本瞭解

使用 Primus Company 保護機密程式碼生成提示

在本程式碼研究室中，我們將扮演 Primus 公司的角色。這間公司非常重視員工資料的隱私權和安全性。Primus 想要部署程式碼生成模型，協助開發人員處理程式設計工作。不過，他們擔心員工提交的提示詞會洩漏機密性，因為這些提示詞通常含有敏感的程式碼片段、內部專案詳細資料或專有演算法。

為什麼 Primus 公司不信任「Operator」？

Primus Corp 經營的市場競爭激烈。他們的程式碼庫含有寶貴的智慧財產，包括專有演算法和敏感的程式碼片段，可提供競爭優勢。他們擔心工作負載運算子可能會從事企業間諜活動。此外，員工提示可能包含 Primus Corp 想要保護的機密「有知情必要」程式碼部分。

為解決這項疑慮，Primus Corp 將運用「受信任空間」，隔離執行程式碼生成模型的推論伺服器。運作方式如下：

- **提示加密：**每位員工都會先使用 Google Cloud 中由 Primus Corp 管理的 KMS 金鑰加密提示，再將提示傳送至推論伺服器。這樣一來，只有可使用對應解密金鑰的「受信任空間」環境，才能解密並存取純文字提示。在實際使用情況中，用戶端加密作業可由可用的程式庫 (例如 [tink](#)) 處理。在本程式碼研究室中，我們將使用 [這個範例用戶端應用程式](#) 進行信封加密。
- **運算子隔離：**只有在「受信任空間」環境中執行的推論伺服器，才能存取用於加密的金鑰，並在受信任的環境中解密提示。加密金鑰的存取權會受到 Workload Identity Pool 保護。由於 Trusted Space 具有隔離保證，即使是工作負載運算子也無法存取用於加密的金鑰和解密內容。

- **使用加速器進行安全推論：**推論伺服器會在 Shielded VM 上啟動 (做為受信任空間設定的一部分)，確保工作負載執行個體未遭啟動或核心層級的惡意軟體或 Rootkit 入侵。這個伺服器會在「受信任空間」環境中解密提示詞，使用程式碼生成模型執行推論，然後將生成的程式碼傳回給員工。
-

2. 設定雲端資源

事前準備

- 使用下列指令複製 [這個存放區](#)，取得本程式碼研究室所需的指令碼。



```
git clone https://github.com/GoogleCloudPlatform/confidential-space.git
```

- 變更本程式碼研究室的目錄。



```
cd confidential-space/codelabs/trusted_space_codelab/scripts
```

- 請確認您已設定必要的專案環境變數，如下所示。如要進一步瞭解如何設定 GCP 專案，請參閱 [這個程式碼研究室](#)。如要瞭解如何擷取專案 ID，以及專案 ID 與專案名稱和專案編號有何不同，請參閱[這篇文章](#)。

```
export PRIMUS_PROJECT_ID=<GCP project id of Primus>
```

- 為專案[啟用帳單](#)。
- 為兩個專案啟用機密運算 API 和下列 API。

```
gcloud services enable \
  cloudapis.googleapis.com \
  cloudresourcemanager.googleapis.com \
  cloudkms.googleapis.com \
  cloudshell.googleapis.com \
  container.googleapis.com \
  containerregistry.googleapis.com \
  iam.googleapis.com \
  confidentialcomputing.googleapis.com
```

- 使用下列指令，為上述資源名稱的變數指派值。您可以視需要自訂資源名稱，也可以使用現有資源 (如果已建立)。(例如 `export PRIMUS_SERVICE_ACCOUNT='my-service-account'`)
1. 您可以使用 Primus 專案中的現有雲端資源名稱，設定下列變數。如果已設定變數，系統會使用 Primus 專案中對應的現有雲端資源。如果未設定變數，系統會從專案名稱產生雲端資源名稱，並以該名稱建立新的雲端資源。以下是資源名稱支援的變數：

<code>\$PRIMUS_PROJECT_REGION</code>	要為 Primus 公司建立區域資源的區域。
<code>\$PRIMUS_SERVICE_LOCATION</code>	Primus 公司要建立資源的位置。

<code>\$PRIMUS_PROJECT_ZONE</code>	要為 Primus 公司建立區域資源的可用區。
<code>\$PRIMUS_WORKLOAD_IDENTITY_POOL</code>	Primus 公司的 Workload Identity Pool，用於保護雲端資源。
<code>\$PRIMUS_WIP_PROVIDER</code>	Primus 公司的 Workload Identity Pool 提供者，其中包含授權條件，可用於 Attestation Verifier Service 簽署的權杖。
<code>\$PRIMUS_SERVICEACCOUNT</code>	Primus 公司的服務帳戶， <code>\$PRIMUS_WORKLOAD_IDENTITY_POOL</code> 用於存取受保護的資源。在這個步驟中，該服務帳戶有權查看儲存在 <code>\$PRIMUS_INPUT_STORAGE_BUCKET</code> 值區中的客戶資料。
<code>\$PRIMUS_ENC_KEY</code>	KMS 金鑰用於加密 Primus 公司員工提供的提示。
<code>\$PRIMUS_ENC_KEYRING</code>	用來為 Primus 公司建立加密金鑰 <code>\$PRIMUS_ENC_KEY</code> 的 KMS 金鑰環。
<code>\$PRIMUS_ENC_KEYVERSION</code>	加密金鑰 <code>\$PRIMUS_ENC_KEY</code> 的 KMS 金鑰版本。預設值為 1。如果您使用過去輪替的現有的金鑰，且版本已更新，請更新此值。
<code>\$PRIMUS_ARTIFACT_REPOSITORY</code>	工作負載 Docker 映像檔的推送目標構件存放區。
<code>\$PRIMUS_PROJECT_REPOSITORY_REGION</code>	構件存放區的區域，其中包含已發布的工作負載 Docker 映像檔。
<code>\$WORKLOAD_VM</code>	工作負載 VM 名稱。
<code>\$WORKLOAD_IMAGE_NAME</code>	工作負載 Docker 映像檔名稱。
<code>\$WORKLOAD_IMAGE_TAG</code>	工作負載容器映像檔的標記。
<code>\$WORKLOAD_SERVICEACCOUNT</code>	有權存取執行工作負載的 Confidential VM 的服務帳戶。
<code>\$CLIENT_VM</code>	用戶端 VM 的名稱，用於執行推論伺服器的用戶端應用程式。
<code>\$CLIENT_SERVICEACCOUNT</code>	<code>\$CLIENT_VM</code> 使用的服務帳戶

- 您需要專案 `$PRIMUS_PROJECT_ID` 的 Storage 管理員、Artifact Registry 管理員、Cloud KMS 管理員、服務帳戶管理員和 IAM Workload Identity Pool 管理員角色。如要瞭解如何使用 GCP 主控台授予 IAM 角色，請參閱[這份指南](#)。
- 針對 `$PRIMUS_PROJECT_ID`，執行下列[指令碼](#)，根據資源名稱的專案 ID，將其餘變數名稱設為值。

```
source config_env.sh
```

注意：為獲得流暢體驗，建議在本程式碼研究室中使用 Cloud Shell。如果使用一般終端機，關閉終端機並重新登入後，您必須重新執行這個步驟。Cloud Shell 會自動處理重新連線。

設定 Primus 公司資源

在這個步驟中，您將設定 Primus 的必要雲端資源。執行下列[指令碼](#)，設定 Primus 的資源。執行指令碼時，系統會建立下列資源：

- KMS 中的加密金鑰 (`$PRIMUS_ENC_KEY`) 和金鑰環 (`$PRIMUS_ENC_KEYRING`)，用於加密 Primus 公司的客戶資料檔案。
- Workload Identity Pool (`$PRIMUS_WORKLOAD_IDENTITY_POOL`)：根據提供者設定的屬性條件驗證聲明。
- 附加至上述工作負載身分集區 (`$PRIMUS_WORKLOAD_IDENTITY_POOL`) 的服務帳戶 (`$PRIMUS_SERVICE_ACCOUNT`) 有權使用 KMS 金鑰解密資料 (使用 `roles/cloudkms.cryptoKeyDecrypter` 角色)、使用 KMS 金鑰加密資料 (使用 `roles/cloudkms.cryptoKeyEncrypter` 角色)、從 Cloud Storage 儲存空間讀取資料 (使用 `objectViewer` 角色)，以及將服務帳戶連結至工作負載身分集區 (使用 `roles/iam.workloadIdentityUser`)。

```
./setup_primus_resources.sh
```

注意：如果您重新執行這個程式碼研究室，並在建立 KMS 金鑰或工作負載身分集區時遇到 `ALREADY_EXISTS` 等錯誤，可能是因為資源已在先前的執行作業中虛刪除。由於這些資源在 30 天內無法重複使用，因此您必須使用其他名稱建立資源。

如要這麼做，請使用下列指令為 Workload Identity Pool 和 KMS 金鑰設定新名稱：

```
export PRIMUS_WORKLOAD_IDENTITY_POOL=<new name of Workload Identity Pool>
```

```
export PRIMUS_ENC_KEY=<new name of KMS Key>
```

然後按照先前的指示，重新執行 `./setup_primus_resources.sh` 指令碼。

3. 建立工作負載

建立工作負載服務帳戶

現在，您要為工作負載建立服務帳戶，並指派必要角色和權限。執行下列[指令碼](#)，在 Primus 專案中建立工作負載服務帳戶。這個服務帳戶會由執行推論伺服器的 VM 使用。

這個工作負載服務帳戶 (`$WORKLOAD_SERVICEACCOUNT`) 將具備下列角色：

- `confidentialcomputing.workloadUser` 取得驗證權杖
- `logging.logWriter`，將記錄檔寫入 Cloud Logging。

```
./create_workload_service_account.sh
```

建立工作負載

在這個步驟中，您會建立工作負載 Docker 映像檔。工作負載將由 Primus 公司製作。本程式碼研究室使用的工作負載是 Python 程式碼，會用到[公開 GCS bucket](#) (Vertex Model Garden) 中的 [codegemma 模型](#)。工作負載會載入 codegemma 模型並啟動推論伺服器，以處理 Primus 開發人員的程式碼生成要求。

在程式碼生成要求中，Workload 會取得包裝的 DEK 和加密提示。工作負載接著會呼叫 KMS API 來解密 DEK，然後使用這個 DEK 解密提示。加密金鑰 (適用於 DEK) 會透過 workload identity pool 受到保護，且系統會授予符合屬性條件的工作負載存取權。下一節將詳細說明授權工作負載的屬性條件。推論伺服器取得解密後的提示詞後，會使用載入的模型生成程式碼，並傳回回應。

執行下列[指令碼](#)，建立工作負載，其中會執行下列步驟：

- 建立 Primus 擁有的 Artifact Registry (`$PRIMUS_ARTIFACT_REGISTRY`)。
- 使用必要資源名稱更新工作負載程式碼。
- 建構推論伺服器工作負載，並建立 Dockerfile，用於建構工作負載程式碼的 Docker 映像檔。本程式碼研究室使用的 Dockerfile [如下](#)。
- 建構 Docker 映像檔，並發布至 Primus 擁有的 Artifact Registry (`$PRIMUS_ARTIFACT_REGISTRY`)。
- 授予 `$WORKLOAD_SERVICEACCOUNT` 的讀取權限給 `$PRIMUS_ARTIFACT_REGISTRY`。工作負載容器需要這項權限，才能從 Artifact Registry 提取工作負載 Docker 映像檔。

```
./create_workload.sh
```

供您參考，以下是本程式碼實驗室中建立及使用的「工作負載」`generate()` 方法 (您可以在[這裡](#)找到完整的「工作負載」程式碼)。


```
def generate():
    try:
        data = request.get_json()
        ciphertext = base64.b64decode(data["ciphertext"])
        wrapped_dek = base64.b64decode(data["wrapped_dek"])
        unwrapped_dek_response = kms_client.decrypt(
            request={"name": key_name, "ciphertext": wrapped_dek}
        )
        unwrapped_dek = unwrapped_dek_response.plaintext
        f = Fernet(unwrapped_dek)
        plaintext = f.decrypt(ciphertext)
        prompt = plaintext.decode("utf-8")
        tokens = tokenizer(prompt, return_tensors="pt")
        outputs = model.generate(**tokens, max_new_tokens=128)
        generated_code = tokenizer.decode(outputs[0])
        generated_code_bytes = generated_code.encode("utf-8")

        response = f.encrypt(generated_code_bytes)
        ciphertext_base64 = base64.b64encode(response).decode("utf-8")
        response = {"generated_code_ciphertext": ciphertext_base64}
        return jsonify(response)

    except (ValueError, TypeError, KeyError) as e:
        return jsonify({"error": str(e)}), 500
```

4. 授權及執行工作負載

授權工作負載

Primus 希望授權工作負載存取用於提示加密的 KMS 金鑰，並根據下列資源的屬性進行授權：

- 內容：已驗證的代碼
- 地點：安全環境
- 對象：值得信賴的運算子

Primus 會使用 [Workload Identity 聯盟](#)，根據這些規定強制執行存取權政策。您可以透過 Workload Identity 聯盟指定 [屬性條件](#)。這些條件會限制哪些身分可以透過 [工作負載身分集區 \(WIP\)](#) 進行驗證。您可以將 Attestation Verifier Service 新增至 WIP，做為 [工作負載身分集區供應商](#)，以便呈現測量結果及強制執行政策。

您先前已在設定雲端資源的步驟中建立 workload identity pool。現在 Primus 會建立新的 OIDC 工作負載身分集區提供者。指定的 `--attribute-condition` 會授權存取工作負載容器。它需要：

- 內容：最新 `$WORKLOAD_IMAGE_NAME` 已上傳至 `$PRIMUS_ARTIFACT_REPOSITORY` 存放區。
- 位置：Confidential Space 受信任的執行環境會在完全支援的 Confidential Space VM 映像檔上執行。
- 對象：Primus `$WORKLOAD_SERVICE_ACCOUNT` 服務帳戶。

```
export WORKLOAD_IMAGE_DIGEST=$(gcloud artifacts docker images describe
${PRIMUS_PROJECT_REPOSITORY_REGION}-
docker.pkg.dev/${PRIMUS_PROJECT_ID}/${PRIMUS_ARTIFACT_REPOSITORY}/${WORKLOAD_IMAGE_NAME}:${WORKLOAD_
IMAGE_TAG} --format="value(image_summary.digest)" --project ${PRIMUS_PROJECT_ID})
```

```
gcloud iam workload-identity-pools providers create-oidc $PRIMUS_WIP_PROVIDER \
--location="global" \
--project="$PRIMUS_PROJECT_ID" \
--workload-identity-pool="$PRIMUS_WORKLOAD_IDENTITY_POOL" \
--issuer-uri="https://confidentialcomputing.googleapis.com/" \
--allowed-audiences="https://sts.googleapis.com" \
--attribute-mapping="google.subject='assertion.sub'" \
--attribute-condition="assertion.swname == 'HARDENED_SHIELDED' && assertion.hwmodel ==
'GCP_SHIELDED_VM' &&
assertion.submods.container.image_digest == '${WORKLOAD_IMAGE_DIGEST}' &&
assertion.submods.container.image_reference == '${PRIMUS_PROJECT_REPOSITORY_REGION}-
docker.pkg.dev/${PRIMUS_PROJECT_ID}/${PRIMUS_ARTIFACT_REPOSITORY}/${WORKLOAD_IMAGE_NAME}:${WORKLOAD_
IMAGE_TAG}' &&
'$WORKLOAD_SERVICEACCOUNT@${PRIMUS_PROJECT_ID}.iam.gserviceaccount.com' in
assertion.google_service_accounts"
```

上述指令會檢查 `hwmodel` 是否設為「GCP_SHIELDED_VM」，以及 `swname` 是否設為「HARDENED_SHIELDED」，藉此驗證工作負載是否在受信任的空間環境中執行。此外，還包含工作負載專屬的斷言，例如 `image_digest` 和 `image_reference`，可提升安全性並確保執行中工作負載的完整性。

執行工作負載

在這個步驟中，我們會在附加加速器的 Trusted Space VM 中執行工作負載。使用 [metadata](#) 標記傳遞必要的 TEE 引數。工作負載容器的引數是透過旗標的「tee-cmd」部分傳遞。如要為工作負載 VM 配備 Nvidia Tesla T4 GPU，請使用 `--accelerator=type=nvidia-tesla-t4,count=1` 旗標。這會將一個 GPU 連接至 VM。我們也需要在中繼資料標記中加入 `tee-install-gpu-driver=true`，觸發安裝適當的 GPU 驅動程式。

```
gcloud compute instances create ${WORKLOAD_VM} \
  --accelerator=type=nvidia-tesla-t4,count=1 \
  --machine-type=n1-standard-16 \
  --shielded-secure-boot \
  --image-project=conf-space-images-preview \
  --image=confidential-space-0-gpupreview-796705b \
  --zone=${PRIMUS_PROJECT_ZONE} \
  --maintenance-policy=TERMINATE \
  --boot-disk-size=40 \
  --scopes=cloud-platform \
  --service-account=${WORKLOAD_SERVICEACCOUNT}@${PRIMUS_PROJECT_ID}.iam.gserviceaccount.com \
  --metadata="^~^tee-image-reference=${PRIMUS_PROJECT_REPOSITORY_REGION}-
docker.pkg.dev/${PRIMUS_PROJECT_ID}/${PRIMUS_ARTIFACT_REPOSITORY}/${WORKLOAD_IMAGE_NAME}:${WO
RKLOAD_IMAGE_TAG}~tee-install-gpu-driver=true~tee-restart-policy=Never"
```

注意：執行個體可使用兩種圖片：`confidential-space-0-gpupreview-796705b` 和 `confidential-space-debug-0-gpupreview-796705b`。你可以使用其中一種。主要差異在於 `confidential-space-0-gpupreview-796705b` 會停用服務，不允許運算子干預工作負載，而 `confidential-space-debug-0-gpupreview-796705b` 會啟用 SSH，運算子可以透過 SSH 連線至 VM。這樣一來，營運人員就能進行偵錯 (但認證服務會在認證權杖中註記已啟用偵錯狀態)。不過，您之後仍需手動關閉 VM。

執行推論查詢

工作負載推論伺服器成功啟動後，Primus 公司的員工現在可以將程式碼生成要求傳送至推論伺服器。

注意：推論伺服器約需 8 到 10 分鐘才能啟動。請等待伺服器完全就緒，再執行下列指令。

在本程式碼研究室中，我們會使用下列指令碼設定用戶端應用程式，與推論伺服器互動。執行[這個指令碼](#)，設定用戶端 VM。

```
./setup_client.sh
```

下列步驟說明如何透過 SSH 連線至用戶端 VM，並在 Python 虛擬環境中執行範例用戶端應用程式。這個範例應用程式使用 Fernet 程式庫進行信封式加密，但請注意，您可以視不同用途調整特定加密程式庫。

```
gcloud compute ssh ${CLIENT_VM} --zone=${PRIMUS_PROJECT_ZONE}
```

執行下列指令，在用戶端 VM 中啟用 Python 虛擬環境，並執行用戶端應用程式。

```
source venv/bin/activate
```

```
python3 inference_client.py
```

這個範例用戶端應用程式的輸出內容會顯示加密和明文提示要求，以及對應的已加密和解密回應。

5. 清除

[這個指令碼](#)可用於清理在本程式碼研究室中建立的資源。在這次清理作業中，系統會刪除下列資源：

- Primus 服務帳戶 (`$PRIMUS_SERVICEACCOUNT`)。
- Primus 加密金鑰 (`$PRIMUS_ENC_KEY`)。
- Primus 的構件存放區 (`$PRIMUS_ARTIFACT_REPOSITORY`)。
- Primus workload identity pool (`$PRIMUS_WORKLOAD_IDENTITY_POOL`) 及其提供者。
- Primus 的工作負載服務帳戶 (`$WORKLOAD_SERVICEACCOUNT`)。
- 工作負載 VM (`$WORKLOAD_VM`) 和用戶端 VM (`$CLIENT_VM`)。

```
./cleanup.sh
```

探索完畢後，請考慮刪除專案。

- 前往 [Cloud Platform Console](#)。
 - 選取要關閉的專案，然後按一下頂端的「刪除」，系統就會排定刪除專案的時間
-